VENDOR RISK ASSESSMENT MATRIX

Third-Party Vendor Risk Evaluation & Scoring Framework

Version: v1.0

Date: mm/dd/yyyy

CONFIDENTIAL

Section 1: Vendor Information

Vendor Name

Enter vendor name

Vendor Website

https://

Primary Contact Name

Name

Primary Contact Email

email@vendor.com

Phone Number

+1 (555) ...

Annual Contract Value ($)

$0.00

Contract Start Date

mm/dd/yyyy

Contract End Date

mm/dd/yyyy

Service/Product Description

Describe the scope of services provided...

Vendor Tier Classification

Select Tier...

Data Access Level

Select Access Level...

Assessment Conducted By

Assessment Date

mm/dd/yyyy

Next Review Date

mm/dd/yyyy

Section 2: Risk Scoring Methodology

Evaluate each control area on a scale of 1-5 based on the criteria provided. The final score determines the risk tier.

1 - Low Risk | 2 - Moderate-Low | 3 - Moderate | 4 - High | 5 - Critical

Section 3: Security Risk Assessment (Category A)

Score: 0/50

#	Control Area	Assessment Criteria	Score (1-5)	Notes
1	Data Encryption	Vendor encrypts data at rest and in transit using industry standards (AES-256, TLS 1.2+)	-	
2	Access Controls	Role-based access controls (RBAC) and least privilege principle enforced	-	
3	MFA	MFA required for all privileged and remote access	-	
4	Vulnerability Mgmt	Regular vulnerability scans and patch management program in place	-	
5	Penetration Testing	Annual third-party penetration testing conducted and results shared	-	
6	Incident Response	Documented IR plan with defined RTO/RPO and breach notification procedures	-	
7	Certifications	Holds relevant certifications (SOC 2 Type II, ISO 27001, PCI DSS, etc.)	-	
8	Network Security	Firewalls, IDS/IPS, network segmentation implemented	-	
9	Endpoint Security	EDR/AV solutions deployed on all endpoints; MDM in place	-	

#	Control Area	Assessment Criteria	Score (1-5)	Notes
10	Awareness Training	Regular employee security training and phishing simulation programs	-	

Category Weight: 40%

Security Risk Summary & Key Findings

Enter summary of security assessment...

Section 4: Compliance Risk Assessment (Category B)

Score: 0/50

#	Control Area	Assessment Criteria	Score (1-5)	Notes
1	Regulatory Compliance	Complies with applicable regulations (GDPR, HIPAA, SOC 2, CCPA, etc.)	-	
2	Data Privacy Policy	Comprehensive, published data privacy policy aligned to requirements	-	
3	Retention & Disposal	Documented data retention schedule and secure disposal procedures	-	
4	Subprocessor Mgmt	Maintains list of subprocessors; notifies clients of changes	-	
5	Contractual Compliance	Willingness to sign DPA, BAA, or other required contractual addenda	-	
6	Audit Rights	Contractually grants customer right to audit or provides third-party reports	-	
7	Legal & Litigation	No significant pending litigation, regulatory actions, or sanctions	-	
8	Export Controls	Complies with export control laws (ITAR, EAR) if applicable	-	
9	Anti-Bribery & Ethics	Anti-bribery, anti-corruption, and code of conduct policies in place	-	

#	Control Area	Assessment Criteria	Score (1-5)	Notes
10	Breach History	No major data breaches in past 3 years; if yes, remediation documented	-	

Category Weight: 35%

Compliance Risk Summary

Enter summary of compliance assessment...

Section 5: Operational Risk Assessment (Category C)

Score: 0/50

#	Control Area	Assessment Criteria	Score (1-5)	Notes
1	Financial Stability	Vendor is financially stable; no signs of distress (D&B score, public financials)	-	
2	Business Continuity	BCP and DR plans documented, tested annually, and available upon request	-	
3	SLA Performance	Defined SLAs with uptime guarantees (≥99.9%) and penalty clauses	-	
4	Concentration Risk	Vendor not sole provider of critical service; alternatives available	-	
5	Geographic Risk	Operations not solely located in high-risk geopolitical regions	-	
6	Supply Chain Risk	Vendor's own supply chain risks assessed; key dependencies identified	-	
7	Staff Retention	Low turnover in key roles; adequate staffing levels maintained	-	
8	Service Desk & Support	Dedicated support channels with defined response times	-	
9	Change Management	Formal change management process; advance notice provided for changes	-	

#	Control Area	Assessment Criteria	Score (1-5)	Notes
10	Exit/Transition Plan	Documented exit plan ensuring data portability and smooth transition	-	

Category Weight: 25%

Operational Risk Summary

Enter summary of operational assessment...

Section 6: Weighted Score Calculator

SECURITY SCORE	COMPLIANCE SCORE	OPERATIONAL SCORE
0.00	0.00	0.00
(Raw / 50) × 40%	(Raw / 50) × 35%	(Raw / 50) × 25%

TOTAL COMPOSITE SCORE

0.00

PENDING

Complete assessments to see risk tier.

Section 7: Risk Findings & Remediation Plan

Finding	Category	Severity	Remediation Action	Owner	Target Date	Statu
Des	Securi	Low	Action...		mm/dd/yyyy	Ope
Des	Securi	Low	Action...		mm/dd/yyyy	Ope
Des	Securi	Low	Action...		mm/dd/yyyy	Ope

Section 8: Vendor Questionnaire & Docs

- [ ] Security questionnaire received and reviewed
- [ ] Data Processing Agreement (DPA) executed
- [ ] Business Associate Agreement (BAA) executed
- [ ] Certificate of Insurance received
- [ ] SOC 2 / ISO 27001 report reviewed
- [ ] Financial statements/D&B report reviewed
- [ ] References checked and verified
- [ ] Fourth-party risk assessment completed
- [ ] Penetration test report reviewed
- [ ] Incident response plan reviewed

Section 9: Overall Risk Assessment & Recommendation

Overall Risk Rating

Select...

Recommendation

Select...

Monitoring Frequency

Select...

Conditions/Exceptions

Executive Summary

Section 10: Sign-Off & Approval

Role	Name	Signature	Date	Status
Risk Assessor			mm/dd/yyyy	Pend
Security Lead			mm/dd/yyyy	Pend
Compliance Officer			mm/dd/yyyy	Pend
IT/Tech Lead			mm/dd/yyyy	Pend
Executive Sponsor			mm/dd/yyyy	Pend

This document is CONFIDENTIAL. Unauthorized disclosure is prohibited.
© 2026 Evolve Edge. All rights reserved.